

Vibe-Pythonpass: Coordinated Vulnerability Disclosure Policy

- **Scope:** This policy applies to all security vulnerabilities discovered in Vibe-Pythonpass services, infrastructure, and dependencies
- **Vulnerability Reporting**
 - Report to: security@vibe-pythonpass.io
 - PGP Key available at: vibe-pythonpass.io/security.pgp
 - Submission format: Plain text or PGP-encrypted
 - Include: Vulnerability description, reproduction steps, CVSS estimate, impact assessment
- **Intake & Acknowledgment**
 - Automatic acknowledgment sent within 2 hours (business hours)
 - Ticket number issued for reference
 - We will not pursue legal action against good-faith security researchers
- **Coordination Timeline**
 - **T+0:** Vulnerability received
 - **T+1 week:** Initial triage and severity assessment
 - **T+2 weeks:** Reproduction confirmed, fix development begins
 - **T+4-8 weeks:** Patch completed and tested (depends on severity)
 - **T+6-12 weeks:** Coordinated public disclosure (fix must be released first)
- **Embargo Agreement**
 - No public disclosure until:
 1. We have deployed a patch to production, OR

2. 90 days have passed since initial report (whichever is earlier)

- Researcher may disclose after embargo lifts
- We welcome coordinated disclosure in security advisories

- **Recognition**

- Acknowledgment in security advisories (unless anonymity requested)
- Public hall of fame: <https://vibe-pythonpass.io/security/hall-of-fame>
- Swag package for critical/high severity vulnerabilities
- Bug bounty payments: EUR 500-5000 based on severity (critical issues higher)

- **Responsible Disclosure Expectations**

- Do not access data beyond what's necessary to confirm vulnerability
- Do not disrupt service or user data
- Do not modify or delete data
- Single point of contact; do not involve law enforcement prematurely
- Test only on personal test accounts or demo environments

- **Exceptions**

- Do not report vulnerabilities publicly before coordinated disclosure
- Do not test on production infrastructure without written authorization
- Social engineering attempts should be reported separately through policy@vibe-pythonpass.io